

REPLY CYBER SECURITY CHALLENGE

CAPTURE THE FLAG EDITION

REFERRAL DIGITAL PRIZE

CODING CHALLENGES
CRYPTO CHALLENGES
WEB CHALLENGES
BINARY CHALLENGES
MISC CHALLENGES

2
3
4
5
6



This document provides some useful and official insight directly from Keen Minds – the team behind the Reply Cyber Security Challenge. It explores the different challenge categories and provides a brief overview of the 2021 challenges, along with several tips and tricks to help you in this year's Challenge!

SIGN UP ON [CHALLENGES.REPLY.COM](https://challenges.reply.com)

CODING CHALLENGES

Typically, Coding category challenges require players to understand the specification of a particular task, like reading handwriting or parsing files, and then implement a program to automate the task in a short amount of time. As requirements can be complex and given the wide availability of libraries and the power of the language, we usually recommend writing the solution using a scripting language like python.

The challenges in 2022 in this category were:

- ▶ **CODING 100** – A series of password-protected zips recursively zipped one inside the other where the password can be obtained by solving crossword puzzles.
- ▶ **CODING 200** – A series of password-protected zips recursively one inside the other where the password can be obtained by finding the shortest path on a maze.
- ▶ **CODING 300** – An Interactive Game consists of four games to be played sequentially where completion of each game will give a passphrase that will be used to access the next game. The four games are respectively: open the lock, guess the number, mastermind and flower meadow.
- ▶ **CODING 400** – In the fourth level you are required to write an interpreter for a custom program language and run a set of provided programs to get the flag.
- ▶ **CODING 500** – To solve the last level of coding it is necessary to reconstruct a sudoku from an image mixed with information obtainable via steganography and solve the sudoku accordingly.

Coding challenges may seem similar to those in the Reply Code Challenge, but they're different as the tasks in the Reply Code Challenge required more theoretical and algorithmic knowledge. In the Reply Cyber Security Challenge Coding category, you need to implement a more practical program. A great tip for this category, and in general, is not to try and reinvent the wheel and to use already available standard libraries – for example, Tesseract – to perform OCR on images.



CRYPTO CHALLENGES

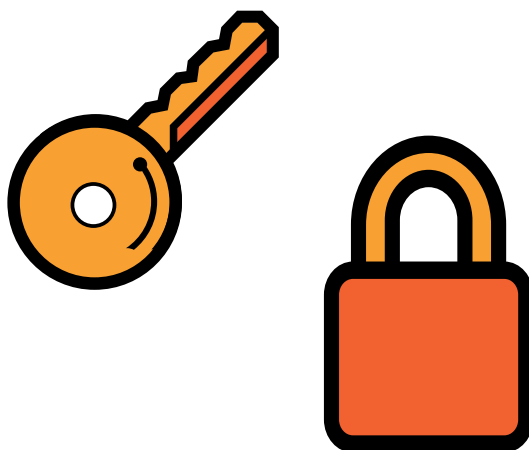
Typically, Crypto category challenges require players to analyse a cryptographic system, with an intended vulnerability or a misconfiguration, to break the used cipher. Most of the time, the challenge provides the source code of the cryptographic system along with a ciphertext associated with a message containing the flag.

The challenges in 2022 in this category were:

- ▶ **CRYPTO 100** – In the first level of crypto you are asked to decrypt a message containing a pdf and find a secret key inside a contract in the blockchain.
- ▶ **CRYPTO 200** – A bit-flipping attack con AES-CBC via a custom web application.
- ▶ **CRYPTO 300** – A data blob file xored with a fixed key, containing a disk image with an rsa-encrypted file to be decrypted by using info available in the other files in the disk image.
- ▶ **CRYPTO 400** – The fourth level consists in a side channel attack. The player must recover the private key from a power consumption signal and be able to decrypt the message with it.
- ▶ **CRYPTO 500** – A Key Mismatch Attack on NewHope cryptosystem.

As standard cryptographic systems are considered secure, you won't not find ciphers used in the wild with the normal configuration. In this category, you'll usually be prompted to analyse an encryption system that, at first sight, may seem secure, but contains something like a bug, misconfiguration, variant, or a misuse of a particular step.

A good tip in this category is to first look for differences with correct and standard implementation of cryptographic systems, as they can be key to finding the vulnerability.



WEB CHALLENGES

Obviously, web challenges always involve a remote website but, depending on the case, the source code or remote service configurations may or may not be provided. In this kind of challenge, vulnerabilities can affect the entire technological stack used for developing a website – for example, as often happens, exploiting an SQL injection in a database or performing an XSS or other standard web attack.

The challenges in 2022 in this category were:

- ▶ **WEB 100** – In the first level of web players need to perform a remote file inclusion attack by loading the flag from a file in the remote filesystem.
- ▶ **WEB 200** – A web application vulnerable to sql injection protected with a custom deny list.
- ▶ **WEB 300** – In this challenge players need to exploit an open redirect in order to modify a jwt to sign certificates with a custom private key.
- ▶ **WEB 400** – A vulnerable web application where players need to perform an ssrf and execute a graphql query.
- ▶ **WEB 500** – In the last web challenge players need to exploit the web application by performing an xss on a custom chat.

Vulnerabilities in web challenges are more or less well defined and categorised. You can find a good reference for a list of web vulnerabilities on the OWASP project page <https://owasp.org/www-community/vulnerabilities/>. A good tip in this category is to analyse the technologies used in a website's source code and look for standard vulnerabilities.



BINARY CHALLENGES

Challenges in this category are divided into two types: reverse and pwning. In the former, players are given a binary file or an obfuscated source and need to reverse and understand the behaviour of the original program. In the latter, players are required to analyse a binary file to find a vulnerability in the program and retrieve some information on a remote service by gaining, for example, remote code execution (RCE).

The challenges in 2022 in this category were:

- ▶ **BINARY 100** – A simple reversing challenge where players are required to find a passphrase by reversing a binary with several checks.
- ▶ **BINARY 200** – The challenge is compiled with all the binary memory corruption protections present at the state of the art. The main purpose of a player is to trigger a command injection which is accessible only via "administrative password" by identify the correct overflow to override a struct pointer in the heap, read the address of a data in the data section and then override a function with the address of the command injection function.
- ▶ **BINARY 300** – The challenge consists in a vulnerable remote binary service where player needs to exploit an uninitialized variable in order to retrieve the flag.
- ▶ **BINARY 400** – A kernel exploitation challenge with a custom written kernel module.
- ▶ **BINARY 500** – The last binary challenge is again a kernel exploitation challenge where player are required to pwn a custom written kernel module.

A good tip for both for reversing and pwning challenges in this category is to use, and know how to use well, the most common tools for binary analysis like IDA, Ghidra, or radare2. You need a lot of patience for these challenges as the main objective is to understand fully how they work by analysing applications at a low level. Tools like decompiler and deobfuscator can help save you a lot of time.



MISC CHALLENGES

Misc (or miscellaneous) challenges don't fit neatly into any other category and can encompass any field of informatics. This can be fought as a "jolly" category.

The challenges in 2022 in this category were:

- ▶ **MISC 100** – The first misc challenge consists in retrieving a deleted zip file from an .img. The zip file is corrupted and it has to be fixed and decrypted with a given password. The flag is inserted in a txt file in the zip.
- ▶ **MISC 200** – A network steganography challenge using the MSB of ID IP packet where packets are sent via an UDP echo server.
- ▶ **MISC 300** – The challenge is a replica of the Chrome Dino offline game, except it is online. Like the original game, the hero must avoid a series of obstacles. In order to win player need to predict the map by analyzing the provided source code.
- ▶ **MISC 400** – A steganography challenge concerning GPS coordinates with positions to search for.
- ▶ **MISC 500** – A mobile challenge consists of two main components: an android app where the levels will be playable and where most of the challenge takes place and a backend flask needed by the app to download the levels\files needed for the challenge. To get the flag, players need to solve three different level by analyzing the mobile app.

Given the variety of topics, a careful analysis of the challenge is necessary to identify any behavior or features that might suggest vulnerabilities, specific usages, or possible useful processing to get to the flag. It may occur that these types of challenges will draw inspiration from past CTFs; as a general hint it may therefore be helpful to try to look for similar problems among writeups from previous years, including different CTFs.

